

GÜVENLİK DUVARI TEMELLERİ

[Kaynak](#)

İÇERİK

1. Firewall (Güvenlik Duvarı) Mekanizmaları ve Ağ Güvenliğindeki Rolü
2. Firewall Türleri ve OSI Referans Modeli Mimarisi
3. Firewall Kural Mimarisi ve Trafik Yönlendirme (Rule & Routing Mechanics)
4. Windows Defender Firewall
5. Linux Güvenlik Duvarı Mimarisi: Netfilter ve UFW Yönetimi

Firewall (Güvenlik Duvarı) Mekanizmaları ve Ağ Güvenliğindeki Rolü

Siber güvenliğin en temel yapı taşlarından biri olan **Firewall** (Ağ trafiğini belirli güvenlik kurallarına göre denetleyen donanım veya yazılım tabanlı sistem), dijital varlıkların dış dünyaya açılan kapısındaki yegane muhafızdır. Temel amacı, bir ağa veya cihaza giren ve çıkan trafiği kontrol altında tutarak, yetkisiz erişimleri (unauthorized access) engellemek ve potansiyel tehditleri daha sisteme sızmadan bertaraf etmektir.

Firewall'un Çalışma Mantığı ve Trafik Denetimi

Dijital dünyada veri akışı, paketler halinde gerçekleşir. Bir cihaz internete bağlandığında veya başka bir cihazla iletişime geçtiğinde, sürekli bir **Incoming** (Gelen) ve **Outgoing** (Giden) trafik akışı oluşur. Firewall, bu trafik akışının tam merkezinde konumlanarak bir filtre görevi görür.

İncelenen Trafik Katmanları

Firewall sistemleri, trafiği incelerken sadece verinin nereden gelip nereye gittiğine bakmaz; modern sistemlerde verinin içeriğini ve protokol özelliklerini de analiz eder. Bu süreçte iki temel trafik yönü kritiktir:

- Ingress Traffic (Gelen Trafik):** Dış ağlardan (genellikle internetten) iç ağa veya spesifik bir cihaza doğru akan veridir. Güvenlik açısından en riskli bölgedir; zira saldırganların sisteme giriş noktası burasıdır.
- Egress Traffic (Giden Trafik):** İç ağdaki bir cihazdan dış dünyaya giden veridir. Bu trafiğin denetlenmesi, sistemde olası bir sızıntı durumunda verilerin dışarı kaçırılmasını (**Data Exfiltration**) engellemek için hayati önem taşır.

Kural Tabanlı Filtreleme Mekanizması (Rule-Based Filtering)

Bir Firewall, kendi başına "neyin iyi, neyin kötü" olduğunu bilemez. Ona bu zekayı veren, yönetici tarafından tanımlanan **Access Control Lists (ACL)** (Erişim Kontrol Listeleri) veya basitçe **Rules** (Kurallar) kümesidir. Her paket bu kontrol noktasından geçerken, Firewall paketi elindeki kurallarla karşılaştırır.

Bir Firewall Kuralının Anatomisi

Genellikle bir kural şu parametreleri içerir:

1. **Source IP (Kaynak IP):** Paket nereden geliyor?
2. **Destination IP (Hedef IP):** Paket nereye gidiyor?
3. **Port Number (Port Numarası):** Hangi servis (HTTP-80, SSH-22, FTP-21 vb.) kullanılıyor?
4. **Protocol (Protokol):** TCP, UDP veya ICMP mi?
5. **Action (Eylem):** Kural eşleştiğinde ne yapılacak? (**Allow/Accept, Deny/Drop, Reject**)

ÖNEMLİ: Teknik fark olarak, **Drop** eyleminde paket sessizce çöpe atılır ve göndericiye bilgi verilmez (bu, taramalarda portun "filtered" görünmesine neden olur). **Reject** eyleminde ise göndericiye bağlantının reddedildiğine dair bir hata mesajı (ICMP Port Unreachable) gönderilir.

Modern Firewall Sistemlerinin Evrimi

Geleneksel Firewall sistemleri sadece paket başlıklarına (header) bakarak karar veren **Stateless** (Durumsuz) yapıdayken, güncel sistemler çok daha gelişmiş özellikler sunar:

- **Stateful Inspection (Durum Bilgili Denetim):** Firewall, aktif bağlantıların durumunu takip eder. Eğer giden bir isteğe (Request) karşılık bir cevap (Response) geliyorsa, bunu otomatik olarak tanır ve ekstra kural gerektirmeden geçişine izin verir.
- **Deep Packet Inspection (DPI - Derin Paket İncelemesi):** Sadece başlığa değil, paketin içindeki verinin (payload) kendisine bakarak zararlı bir kod veya imza olup olmadığını kontrol eder.
- **Next-Generation Firewall (NGFW):** Uygulama katmanındaki trafiği (L7) tanıyabilen, içinde **IPS** (Intrusion Prevention System - Saldırı Engelleme Sistemi) barındıran ve kullanıcı bazlı filtreleme yapabilen hibrit yapılardır.

Neden Bir Firewall'a İhtiyaç Duyarız? (Analitik Bakış)

Bir sistemde Firewall olmaması, kapısı ve duvarı olmayan bir binaya benzer. Siber saldırganlar, ağınızdaki açık portları tespit etmek için **Enumeration** (Bilgi toplama/numaralandırma) çalışmaları yaparlar. Eğer bir Firewall yoksa:

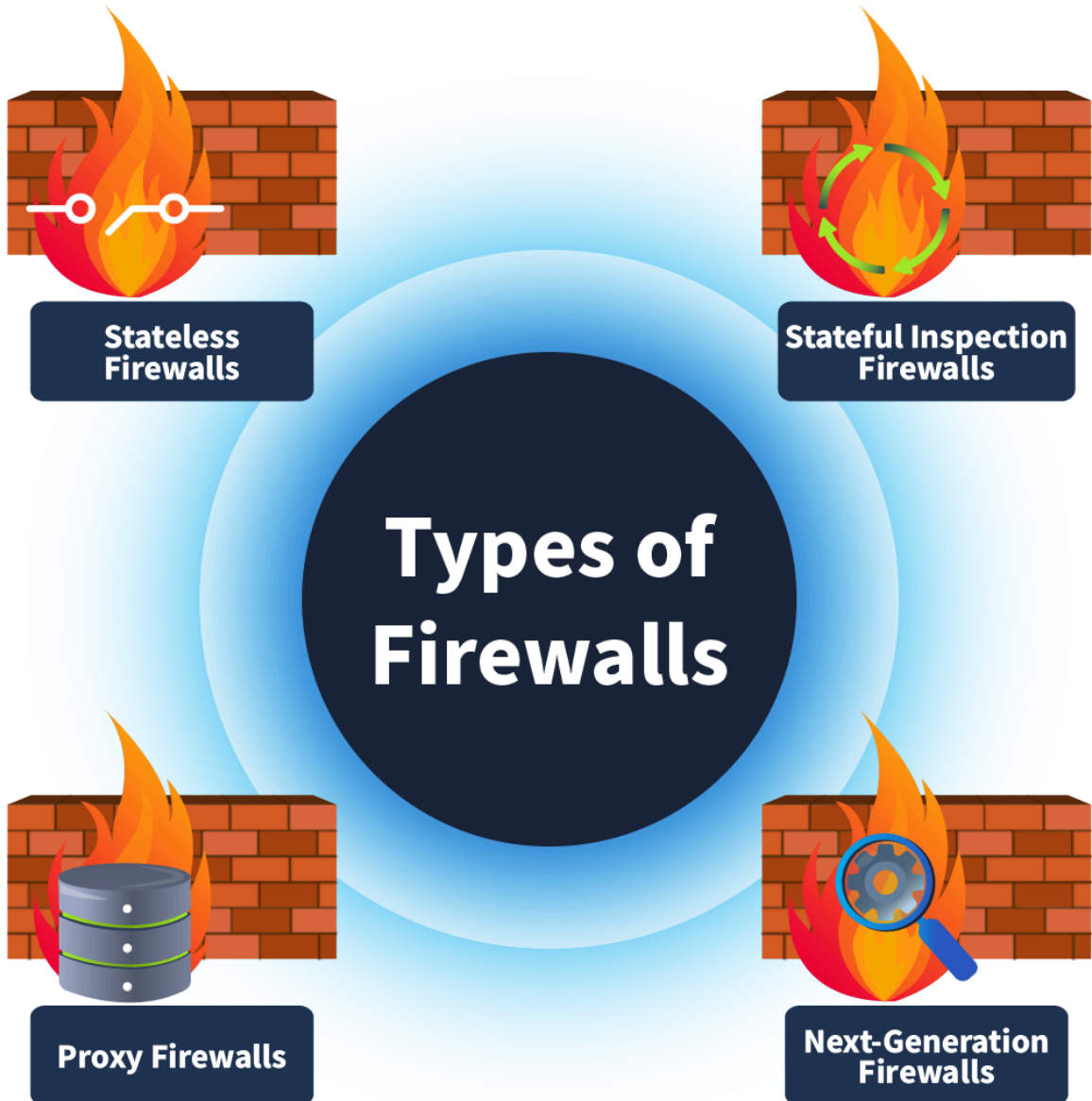
1. Saldırganlar doğrudan kritik servislerinize (örneğin veritabanı portları) bağlanabilir.
2. Kötü amaçlı yazılımlar (Malware) komuta kontrol merkezleriyle (**C2 - Command and Control**) hiçbir engel olmadan iletişim kurabilir.

3. Ağ kaynakları, **DDoS** (Dağıtık Hizmet Engelleme) saldırılarıyla kolayca tüketilebilir.

DİKKAT: Firewall bir "gümüş kurşun" değildir. Eğer kural setleri (Rulesets) yanlış yapılandırılmışsa veya "Permit Any Any" (Her yerden her yere izin ver) gibi gevşek kurallar içeriyorsa, güvenlik duvarı işlevsiz kalacaktır. Güvenlikte **Least Privilege** (En Düşük Yetki) prensibi gereği, Firewall kuralları "Default Deny" (Varsayılan olarak engelle) mantığında olmalı ve sadece gerekli trafiğe izin verilmelidir.

Firewall Türleri ve OSI Referans Modeli Mimarisi

Siber güvenlikte savunma mimarisi tasarlanırken tek bir güvenlik duvarı modeli her senaryoya uyum sağlayamaz. Organizasyonlar, ağlarına giren zararlı trafiği filtreleme ihtiyacını fark ettikçe, her biri spesifik bir amaca hizmet eden ve **OSI (Open Systems Interconnection) Modelinin** farklı katmanlarında (Layer) çalışan spesifik Firewall türleri geliştirilmiştir. Bir Firewall'un hangi OSI katmanında çalıştığını bilmek, onun neleri engelleyip neleri göremeyeceğini anlamanın anahtarıdır.



1. Stateless Firewall (Durumsuz Güvenlik Duvarı)

Bu tür, siber güvenliğin en ilkel ama en hızlı denetim mekanizmasıdır. **Layer 3 (Network Katmanı)** ve **Layer 4 (Transport Katmanı)** üzerinde çalışır.

Çalışma Mantığı:

Stateless Firewall, üzerinden geçen her veri paketini tamamen izole ve bağımsız bir olay olarak değerlendirir. Önceki bağlantıların durumunu, bir paketin bir iletişimin parçası olup olmadığını (örneğin bir TCP el sıkışmasının neresinde olduğunu) "hatırlamaz". Ağ trafiğini sadece önceden tanımlanmış sabit kurallara (IP adresleri, portlar, protokoller) göre filtreler.

Analitik Derinlik:

Bu "amnezi" (unutkanlık) durumu ciddi bir güvenlik açığı doğurabilir. Örneğin, bir saldırgandan gelen zararlı bir paket kurala takılıp düşürülse (drop) bile, Firewall bu kaynağı kara listeye almaz. Aynı saldırgandan gelen bir sonraki paket yine aynı kural setinden baştan geçmek zorundadır. Karmaşık politikalar uygulanamaz. Ancak hiçbir hafıza tutmadığı (RAM tüketimi düşük olduğu) için yüksek hızlı ağlarda (**High-speed networks**) ilk karşılama noktası (Edge router'lar vb.) olarak hızı nedeniyle tercih edilir.

Bash

```
# ÖRNEK BİR STATELESS KURAL MANTIĞI (Sözde Kod)
# Kaynak: 192.168.1.50, Hedef: Herhangi, Port: 80 -> İZİN VER
# Firewall sadece bu kurala bakar. Paketin bir HTTP isteğine ait bir ACK mı,
# yoksa sahte bir SYN flood mu olduğunu umursamaz. Şartlar uyuyorsa geçirir.
```

Yukarıdaki mantık, Stateless mimarinin sadece başlık (header) verisine bakarak ne kadar yüzeysel bir denetim yaptığını göstermektedir.

2. Stateful Firewall (Durum Bilgili Güvenlik Duvarı)

Stateless mimarinin zafiyetlerini kapatmak üzere geliştirilen bu sistem de **Layer 3** ve **Layer 4** seviyelerinde çalışır ancak çok kritik bir eklenti barındırır: **State Table** (Bağlantı Durum Tablosu).

Çalışma Mantığı:

Sadece önceden belirlenmiş kurallara bakmakla kalmaz, aynı zamanda gerçekleşen bağlantıların geçmişini takip eder. Bir kaynak adresten gelen paket kural seti tarafından onaylandığında, **Stateful Firewall** bu bağlantıyı durum tablosuna kaydeder. Artık bu aktif oturuma (session) ait olan sonraki paketler, kural listesini baştan sona taramak zorunda kalmadan, otomatik olarak güvenilir kabul edilip geçirilir. Aynı şekilde engellenen zararlı bir trafiğin durumu da kaydedilir ve o kaynaktan gelen ardışık paketler doğrudan reddedilir.

Analitik Derinlik:

Bu mimari, saldırganların güvenlik duvarını atlatmak için kullandıkları "sahte ACK paketleri" gönderme taktiklerini boşa çıkarır. Çünkü Firewall durum tablosuna bakar: *"İçeriden dışarıya bu IP için başlatılmış bir SYN isteği yok, dolayısıyla bu dışarıdan gelen ACK paketi sahtedir"* diyerek trafiği anında keser.

Plaintext

# ÖRNEK BİR STATE TABLE (Durum Tablosu) ÇIKTISI				
Protokol	Kaynak IP	Hedef IP	Durum	Zaman Aşımı
TCP	10.0.0.5:44321	203.0.113.1:80	ESTABLISHED	299 sn

Bu sanal çıktı, Stateful Firewall'un hafızasını temsil eder. 10.0.0.5 ile 203.0.113.1 arasındaki bağlantı zaten kurulmuş (ESTABLISHED). Bu ikili arasında akan paketler ekstra kural denetimine girmeden doğrudan işlenir.

3. Proxy Firewall (Uygulama Seviyesi Ağ Geçidi)

Önceki nesil güvenlik duvarlarının en büyük kör noktası, paketin sadece zarfına (header) bakıp, mektubun içeriğini (payload/veri) okuyamamalarıdır. **Proxy Firewall, Layer 7 (Application Katmanı)** üzerinde çalışarak bu sorunu çözer.

Çalışma Mantığı:

İç ağ (Private Network) ile dış dünya (Internet) arasında bir "aracı" (**Intermediary / Man-in-the-Middle**) görevi görür. İç ağdaki bir kullanıcı dışarıya bir istek yaptığında, istek önce Proxy'ye gider. Proxy bu isteğin içeriğini (örneğin HTTP başlıklarını, URL'i, aktarılan dosyayı) derinlemesine inceler. Eğer içerik güvenlik politikalarına uygunsa, **Proxy kendi IP adresi üzerinden hedef sunucuya yeni bir bağlantı açar.**

Analitik Derinlik:

Bu sistemin en büyük teknik avantajı **Anonymity** (Anonimlik) sağlamasıdır. Hedef sunucu, iç ağdaki kullanıcının gerçek IP'sini (Internal IP) asla göremez, sadece Proxy'nin IP'sini görür. Ayrıca veri içeriği denetlendiği için (**Content Filtering**), zararlı bir SQL Injection payload'u barındıran bir HTTP isteği veya kısıtlanmış bir kelime içeren veri aktarımı doğrudan bu katmanda engellenir. Uygulama kontrolü (**Application Control**) en üst düzeydedir.

ÖNEMLİ: En büyük dezavantajı performans darboğazıdır. Her bağlantıyı sonlandırıp yeniden başlatmak (Terminate and Re-originate) ve içerik taramak, gecikmeye (latency) neden olur.

4. Next-Generation Firewall (NGFW - Yeni Nesil Güvenlik Duvarı)

Günümüz siber güvenlik endüstrisinin altın standardıdır. **Layer 3'ten Layer 7'ye kadar tam kapsamlı** bir OSI entegrasyonu ile çalışır. Temel güvenlik duvarı özelliklerini, **IPS (Intrusion Prevention System - Saldırı Önleme Sistemi)** ve diğer gelişmiş analiz araçlarıyla birleştirir.

Teknik Derinlik ve Gelişmiş Modüller:

- **Deep Packet Inspection (DPI):** Tıpkı Proxy gibi paketin içeriğini inceler ancak bunu çok daha hızlı ve hat içi (inline) yapar.
- **Heuristic Analysis (Sezgisel Analiz):** Sadece bilinen saldırı imzalarını (signature-based) engellemekle kalmaz. Ağdaki anomalileri ve atak örüntülerini analiz ederek, daha önce hiç görülmemiş (Zero-Day) zararlı aktiviteleri ağa ulaşmadan engeller.
- **SSL/TLS Decryption (Şifre Çözme ve İnceleme):** Günümüzde kötü amaçlı yazılımlar komuta-kontrol sunucularıyla şifreli (HTTPS) iletişim kurarak klasik Firewall'ları kör eder. NGFW, araya girerek SSL/TLS trafiğinin şifresini çözer, içindeki veriyi zararlı etkinliklere veya **Threat Intelligence** (Tehdit İstihbaratı) beslemelerine karşı tarar, sorun yoksa tekrar şifreleyerek hedefe iletir. Bu, modern ağ savunmasının kalbidir.

Firewall Mimarileri Karşılaştırma Matrisi

Sertifikasyon sınavlarında (örneğin CompTIA Security+ veya benzeri) sistem mimarisini tasarlarken seçeceğiniz ürünün kapasitesini bilmek puan kazandırır.

Firewall Tipi	Temel Karakteristikler ve Teknik Odak Noktaları
Stateless	• Sadece temel L3/L4 başlık filtrelemesi yapar. • Bağlantı geçmişini tutmaz (State track yoktur). • Düşük işlemci gücü gerektirdiği için yüksek hızlı ağlarda etkilidir.
Stateful	• Trafik örüntülerini (TCP State) tanır. • Karmaşık, duruma bağlı kurallar uygulanabilir. • Aktif ağ bağlantılarını izler ve tablo tutar.
Proxy	• Paketlerin içindeki veriyi (Payload) okur ve analiz eder. • İçerik filtreleme (Content Filtering) ve L7 uygulama kontrolü sağlar. • IP maskeleye yapar (Bağlantıyı kendisi kurar). • SSL/TLS verisini çözüp inceleyebilir.
NGFW	• Gelişmiş tehdit koruması (Threat Protection) ve entegre IPS sunar. • Sezgisel analiz (Heuristic) ile anomali tespiti yapar. • Trafiği yavaşlatmadan SSL/TLS şifre çözme ve paket inceleme sağlar.

DİKKAT: Modern kurumsal ağlarda genellikle hibrit bir yapı kullanılır. Dış sınırlarda DDoS ve çöp trafiği hızlıca düşürmek için Stateless/Stateful cihazlar konumlandırılırken, iç ağa giden

kritik noktalarda trafiğin anatomisini çıkarmak için NGFW sistemleri yerleştirilir. Bu **Defense in Depth** (Derinlemesine Savunma) prensibinin temelidir.

Firewall Kural Mimarisi ve Trafik Yönlendirme (Rule & Routing Mechanics)

Bir güvenlik duvarının varsayılan olarak sahip olduğu kurallar (genellikle tüm dış trafiği reddeden **Default Deny** prensibi) sağlam bir temel oluştursa da, kurumsal bir ağın iş gereksinimlerini karşılamak için yetersizdir. Ağ yöneticileri, ağın **Attack Surface** (Saldırı Yüzeyi - bir sisteme dışarıdan sızılacak tüm olası noktaların bütünü) alanını minimumda tutarken, meşru iş trafiğine izin vermek için özelleştirilmiş kural setleri (Custom Rulesets) yazmak zorundadır. Örneğin, dışarıdan gelen tüm **SSH** (Secure Shell - uzaktan komut çalıştırma protokolü) bağlantılarını reddederken, sadece belirli bir yönetici IP adresine (**Jump Server** veya **Bastion Host**) izin vermek bu mimarinin temel operasyonudur.

Bir Firewall Kuralının Anatomisi

Bir Firewall, üzerinden geçen her veri paketini incelediğinde, yazdığımız kuralları yukarıdan aşağıya (Top-Down) doğru sırayla okur ve ilk eşleşen kuraldaki eylemi gerçekleştirir. Güvenli ve kusursuz bir kural yazmak için 6 temel bileşenin mantıksal olarak birbiriyle bağlanması gerekir:

1. **Source Address (Kaynak Adres):** Trafiği başlatan, paketin doğduğu OSI Layer 3 (IP) adresidir. Tek bir makine (Host) veya bütün bir alt ağ (Subnet) olabilir.
2. **Destination Address (Hedef Adres):** Paketin ulaşmaya çalıştığı nihai IP adresidir.
3. **Protocol (Protokol):** İletişimin dilini belirler. Genellikle Layer 4 seviyesindeki **TCP** (Güvenilir, bağlantı odaklı) veya **UDP** (Hızlı, bağlantısız) protokolleridir.
4. **Port:** Trafiğin hedef makinede hangi servise/kapıya gitmek istediğini belirten mantıksal numardır (Örn: Web için **80/443**, DNS için **53**).
5. **Direction (Yönlülük):** Trafiğin güvenlik duvarına göre ne yöne aktığını (İçeri mi, dışarı mı?) belirtir.
6. **Action (Eylem):** Yukarıdaki 5 şart eşleştiğinde güvenlik duvarının pakete ne yapacağına (İzin ver, Engelle, Yönlendir) karar verdiği tetik mekanizmasıdır.

Trafik Aksiyonları (Actions) ve Arka Plan Mantığı

Bir veri paketi bir kuralın kapsamına girdiğinde, Firewall üç temel aksiyondan birini alır. Aşağıdaki yapılandırmalar, teorik Firewall kurallarının mantıksal dökümleridir.

1. ALLOW (İzin Verme) Aksiyonu

"Allow" eylemi, kurallarda tanımlanan spesifik trafiğin güvenlik duvarından geçişine onay verir. Güvenlikte her "Allow" kuralı, duvarda açılmış kontrollü bir deliktir; bu yüzden en dar kapsama (Least Privilege) sahip olmalıdır.

Plaintext

[KURAL 01 – INTERNET ERIŞİMİ]

Action	Source	Destination	Protocol	Port	Direction
ALLOW	192.168.1.0/24	Any	TCP	80	Outbound

Çıktı ve Mantıksal Analiz:

- Burada **192.168.1.0/24** CIDR notasyonu kullanılarak tüm bir iç ağ (254 potansiyel cihaz) hedeflenmiştir.
- Bu kural, iç ağımızdaki cihazların dış dünyadaki (**Any** hedefi) herhangi bir web sunucusuna şifresiz **HTTP** (Port **80**) trafiği başlatmasına izin verir.
- Direction: Outbound** olması kritiktir. Bu kural dışarıdan içeriye (Inbound) bir web isteğine izin vermez, sadece içerideki bir kullanıcının internette gezinmesini sağlar. Eğer bu adım başarısız olsaydı (yani engellenseydi), iç ağdaki hiçbir çalışan web sitelerine erişemezdi.

2. DENY (Engelleme) Aksiyonu

"Deny" eylemi, eşleşen trafiğin anında kesilmesini sağlar. Güvenlik operasyon merkezleri (SOC), tespit ettikleri zararlı IP adreslerinden (Malicious IPs) gelen trafiği veya kritik iç servislere yönelik yetkisiz erişimleri engellemek için bu aksiyonu kullanır.

Plaintext

[KURAL 02 – KRİTİK SERVİS KORUMASI]

Action	Source	Destination	Protocol	Port	Direction
DENY	Any	192.168.1.0/24	TCP	22	Inbound

Çıktı ve Mantıksal Analiz:

- Dış dünyadaki herhangi bir IP adresinden (**Any**), iç ağımızdaki herhangi bir cihaza (**192.168.1.0/24**) doğru başlatılacak tüm uzaktan yönetim (Port **22 - SSH**) istekleri kapıda engellenmektedir.
- Neden bu komutu/kuralı kullanıyoruz?** Çünkü **22. port** doğrudan sistemin komut satırına (Shell) erişim sağlar ve saldırganların internet üzerinden en çok kaba kuvvet (Brute-Force) saldırısı düzenlediği hedeftir.
- ÖNEMLİ:** Bu global "Deny" kuralından hemen önce, sadece şirket yöneticilerinin statik IP adreslerine "Allow" veren spesifik bir kural yazılmalıdır. Aksi takdirde, sistem yöneticileri de uzaktan sistemlere bağlanamaz.

3. FORWARD (Yönlendirme) Aksiyonu

"Forward" eylemi, Firewall'un sadece bir bariyer değil, aynı zamanda akıllı bir yönlendirici (Router/Gateway) gibi çalışmasını sağlar. Genellikle **DNAT** (Destination Network Address

Translation - Hedef Ağ Adresi Çevirisi) veya yaygın adıyla **Port Forwarding** yapılandırmalarında kullanılır.

Plaintext

[KURAL 03 – WEB SUNUCUSU YAYINI]

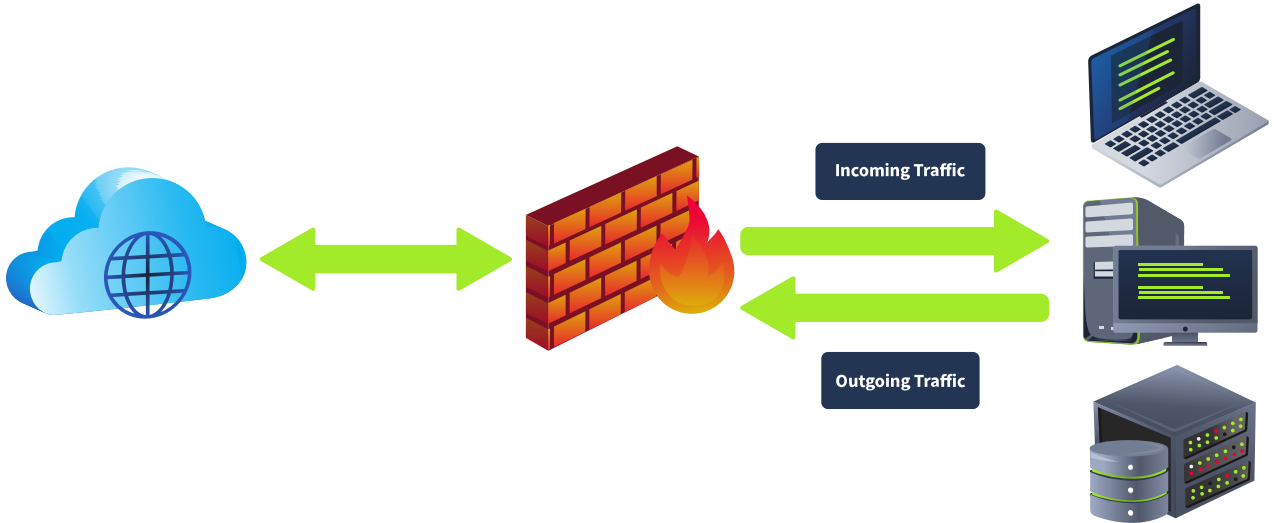
Action	Source	Destination	Protocol	Port	Direction
FORWARD	Any	192.168.1.8	TCP	80	Inbound

Çıktı ve Mantıksal Analiz:

- Dış dünyadan (**Any**) güvenlik duvarımızın genel (Public) IP adresine gelen **TCP 80** (HTTP) istekleri Firewall tarafından karşılanır.
- Firewall bu paketi reddetmek yerine, hedefini iç ağdaki (Private Network) izole edilmiş **192.168.1.8** IP adresli web sunucusuna doğru **yönlendirir (Forward)**.
- Bu sayede dışarıdaki bir kullanıcı, web sunucusunun gerçek yerel IP adresini bilmeden veya ona doğrudan ulaşmadan web sitesini görüntüleyebilir. Sunucu güvende kalır.

Trafik Yönlülüğü (Directionality of Rules) ve Savunma Stratejileri

Firewall kuralları, trafiğin akış yönüne göre üç ana kategoriye ayrılır. Sektörde bir ağın ne kadar iyi korunduğu, sadece içeri giren değil, dışarı çıkan trafiğin ne kadar iyi yönetildiğiyle ölçülür.



- Inbound Rules (Gelen Trafik Kuralları):** Dış ağdan (genellikle güvensiz İnternet bölgesinden) iç ağa doğru olan trafiği denetler. Öncelikli amacı **İhlali (Breach)** önlemektir. Yukarıdaki örnekte dışarıdan gelen HTTP isteklerine sadece web sunucusu için izin verilmesi Inbound stratejisidir.
- Outbound Rules (Giden Trafik Kuralları):** İç ağdaki cihazların dış dünya ile kuracağı iletişimi denetler. Öncelikli amacı **Veri Sızıntısını (Data Exfiltration)** ve zararlı yazılım iletişimini engellemektir.

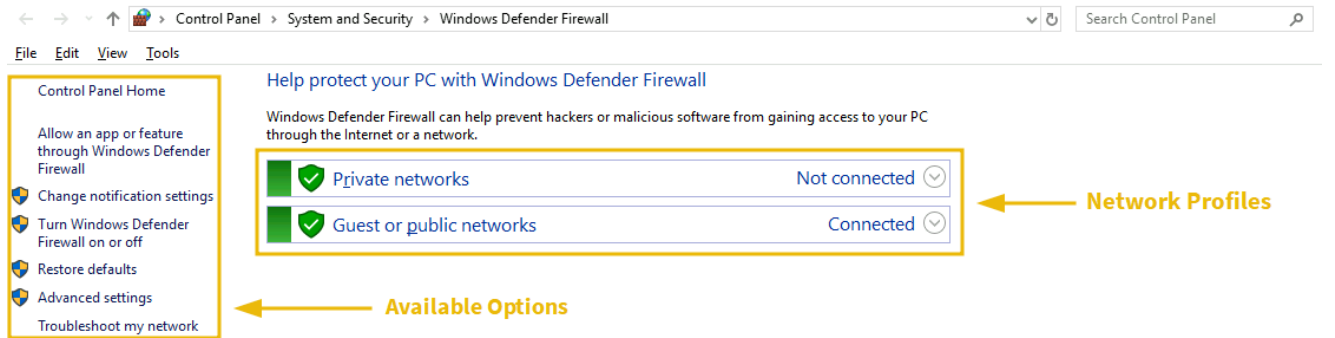
- **Teknik Derinlik:** Sadece e-posta sunucunuzun (Mail Server) **SMTP (Port 25)** üzerinden dışarıya çıkmasına izin verip diğer tüm cihazların 25. portunu engellemek kusursuz bir Outbound kuralıdır. Böylece, ağınıza sızan bir zararlı yazılım (Malware), bilgisayarları spam e-posta gönderen bir **Botnet**'e dönüştüremez.
- **Forward Rules (Yönlendirme Kuralları):** Trafiğin Firewall üzerinden geçerek farklı ağ segmentleri (örneğin İnternet'ten DMZ ağına veya LAN'dan VLAN'lara) arasında güvenli aktarılmasını sağlar. İç ağ segmentasyonunun (Network Segmentation) temelidir.

DİKKAT: Bir Firewall kural tablosu oluştururken altın kural hiyerarşidir. Firewall kural listesini yukarıdan aşağıya doğru okur. En tepeye spesifik (dar) izin kuralları, en alta ise her şeyi engelleyen (Deny Any Any) kuralı yerleştirilmelidir. Eğer genel engelleme kuralı en üstte olursa, altındaki "Allow" veya "Forward" kurallarının hiçbir hükmü kalmaz ve trafik anında kesilir.

Windows Defender Firewall

Windows işletim sistemlerinde yerleşik olarak (built-in) gelen Windows Defender **Firewall** (Güvenlik Duvarı), sistemin gelen (**Inbound**) ve giden (**Outbound**) ağ trafiğini kontrol eden, kural tabanlı (rule-based) temel ağ güvenliği bileşenidir. Geleneksel bir güvenlik duvarının tüm temel işlevlerini barındırır; belirli programlara izin verme, trafiği reddetme veya tamamen özelleştirilmiş ağ kuralları oluşturma imkanı sunar.

Sistemin maruz kaldığı ağ trafiğini kısıtlamak, özellikle bir ihlal (breach) durumunda yanıl hareketleri (lateral movement) engellemek veya zararlı yazılımların Komuta ve Kontrol (C2) sunucularıyla iletişimini kesmek için bu bileşene tam hakimiyet kritik önem taşır.

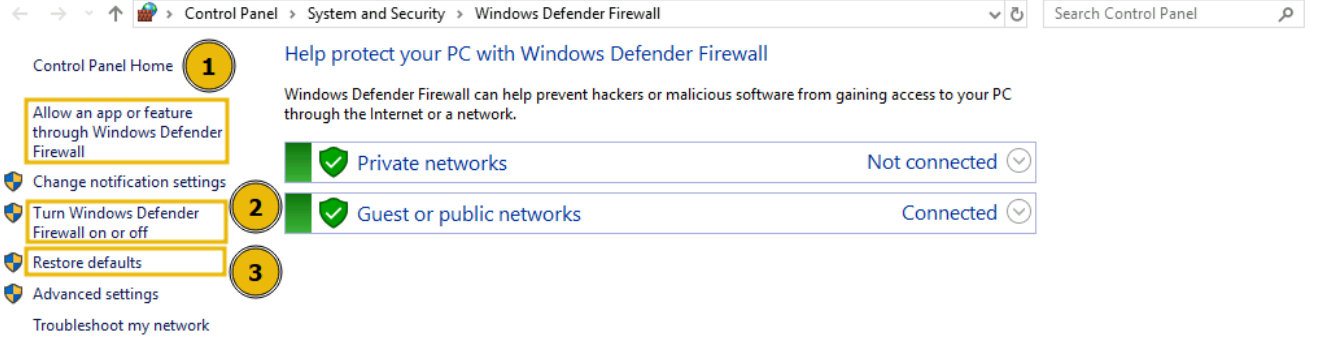


Network Profiles (Ağ Profilleri) ve NLA Mimarisi

Windows, bulunduğunuz ağın güvenilirlik seviyesini belirlemek için **Network Location Awareness (NLA)** (Ağ Konumu Farkındalığı) servisini kullanır. NLA, bağlanılan ağın karakteristiklerini analiz eder ve uygun olan profilin **Firewall** kurallarını otomatik olarak sisteme uygular. İki temel profil bulunur ve her biri için birbirinden tamamen izole edilmiş, farklı kural setleri yapılandırılabilir:

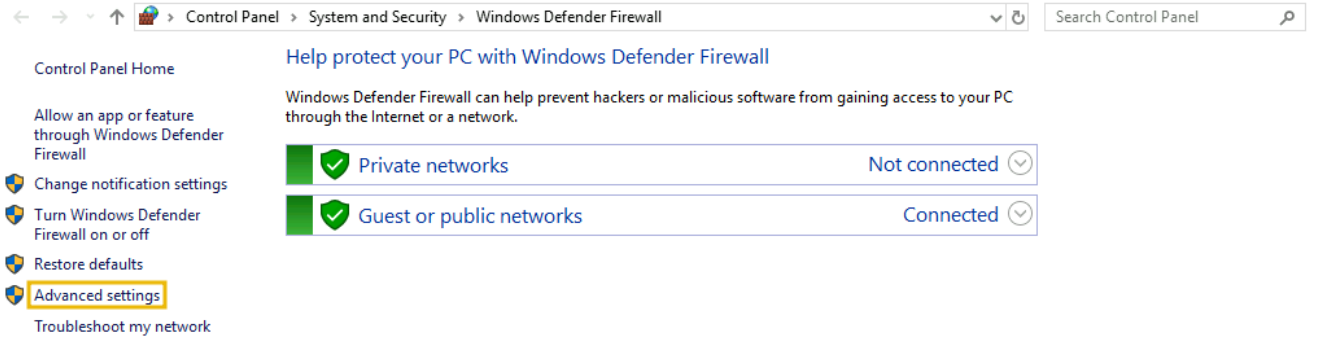
- **Private Networks (Özel Ağlar):** Ev veya kurum içi (Corporate LAN) gibi güvenilir ağlara bağlandığımızda uygulanan yapılandırma değildir. Genellikle dosya paylaşımı (SMB, Port **445**) veya yerel ağ keşif protokolleri bu profilde daha esnek bırakılır.

- **Guest or Public Networks (Misafir veya Ortak Ağlar):** Kafe, havalimanı gibi dış ve güvenilmeyen ağlarda devreye giren katı profildir. Güvenlik duruşu (security posture) gereği, bu profilde tüm **Inbound** (gelen) bağlantılar varsayılan olarak bloklanmalı ve sadece internete çıkış için gereken zorunlu **Outbound** (giden) bağlantılara izin verilmelidir.

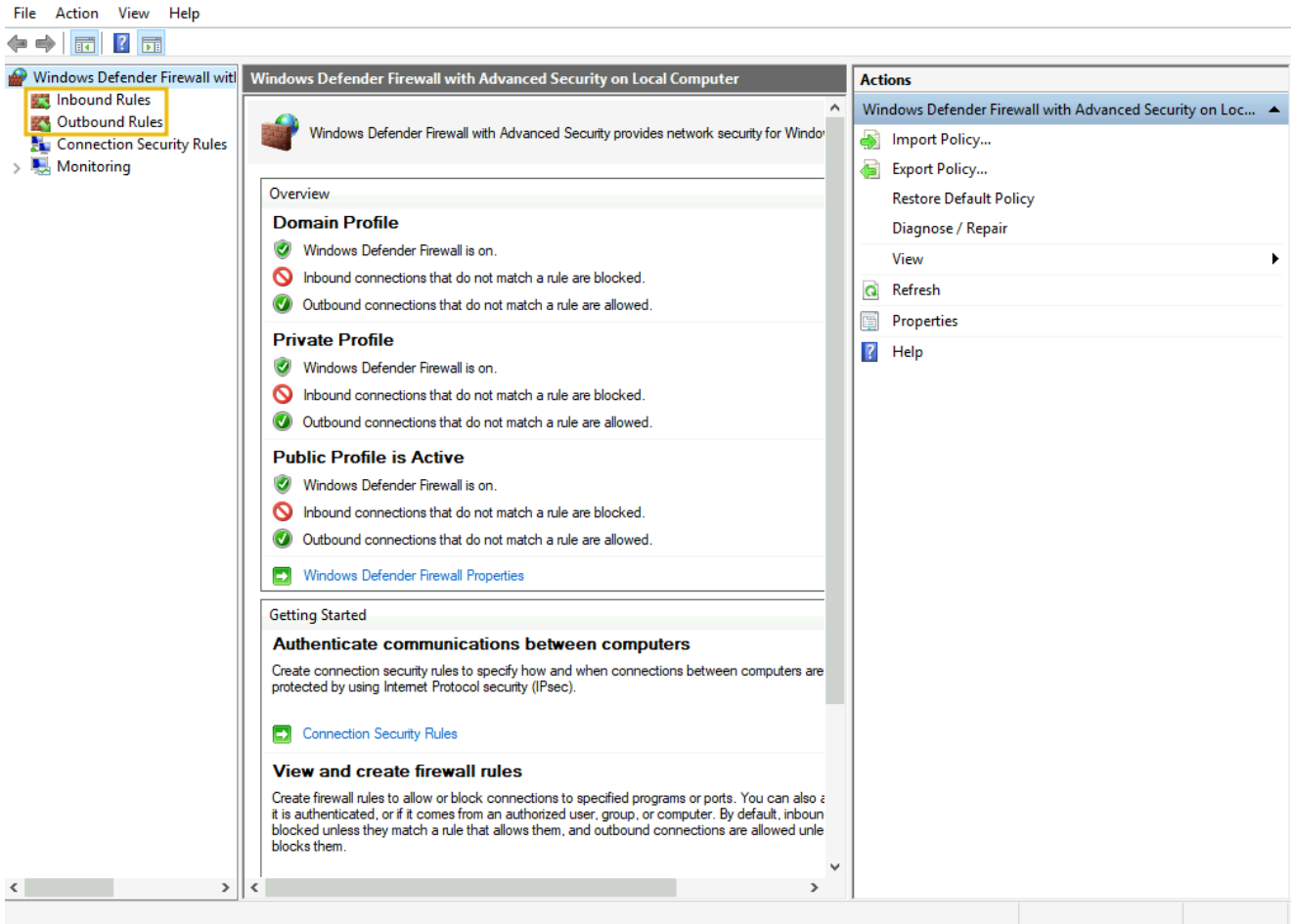


ÖNEMLİ: Microsoft, sorun giderme (troubleshooting) aşamalarında bile **Firewall**'un tamamen kapatılmasını önermez. Savunma yüzeyini sıfırlamak yerine, ana kontrol panelinden "Tüm gelen bağlantıları engelle" (Block all incoming connections) seçeneğini aktif etmek teknik olarak çok daha güvenli bir geçici çözümdür. Ayrıca, yapılandırmalar kontrolden çıktığında "Restore Defaults" (Varsayılanları Geri Yükle) seçeneği ile sistem fabrika ayarlarına döndürülebilir.

Advanced Settings: Custom Rules (Özel Kurallar) Oluşturma Mantığı



Temel uygulamaya izinlerinin ötesinde, spesifik port, protokol veya IP bazlı kısıtlamalar yapmak için "Advanced Settings" (Gelişmiş Ayarlar) menüsü kullanılır. Bu panel, savunma mimarisini granüler (ince ayarlı) olarak yapılandırdığımız yerdir.



Ağ üzerinde **HTTP** (Port **80**) ve **HTTPS** (Port **443**) trafiğini tamamen kesecek bir **Outbound** (Giden) kuralının adım adım mantıksal inşası aşağıdadır. Bu kural aktif edildiğinde, sistem internetteki hiçbir web sunucusuna bağlanamayacaktır.

Senaryo: Web Trafiğini (Port 80 ve 443) Bloklama

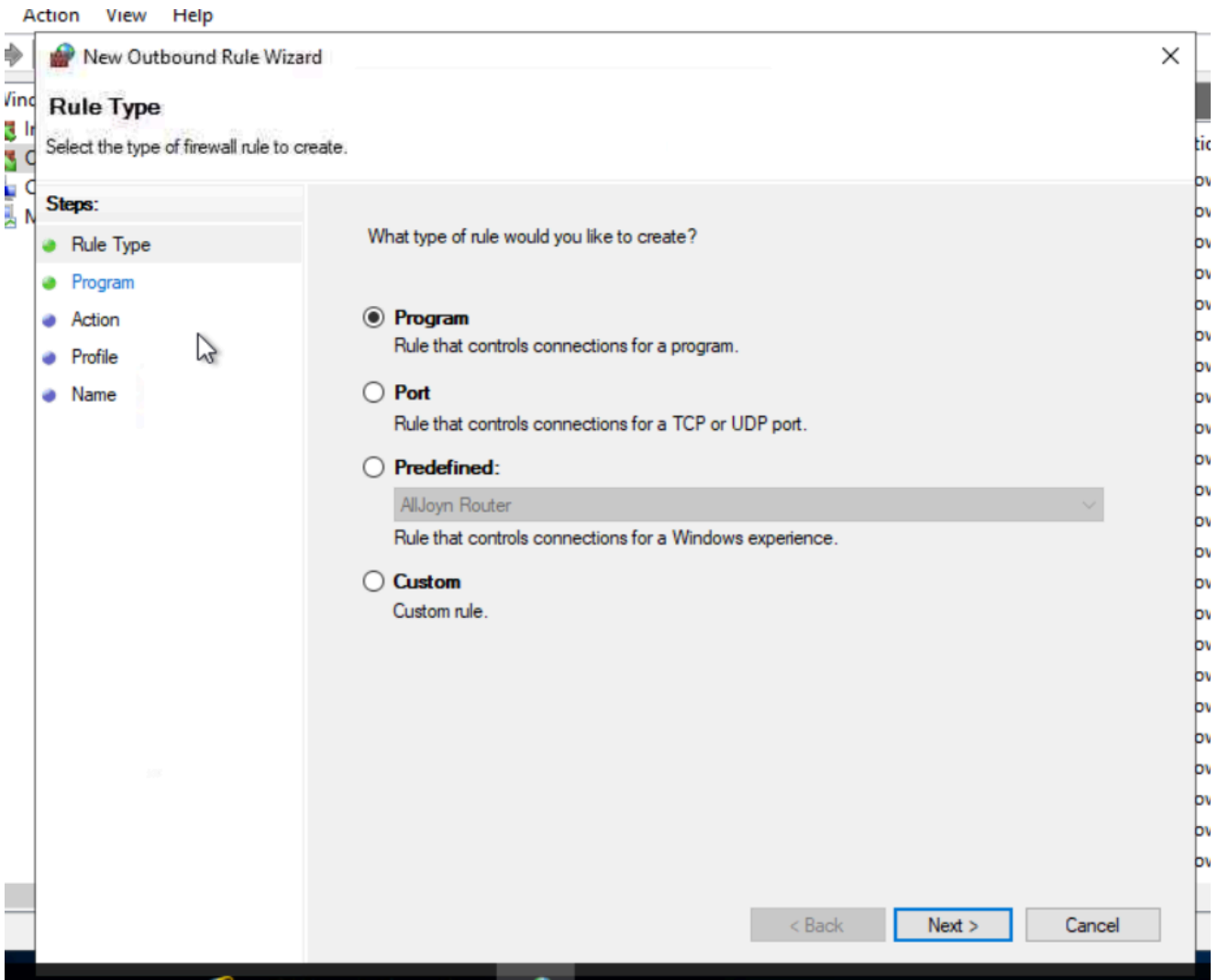
Kuralı yazmadan önce hedefe erişimimizin olduğunu doğrulamak, kuralın çalıştığını kanıtlamak için elzemdir.

```
Invoke-WebRequest -Uri http://10.10.10.10/ -UseBasicParsing
```

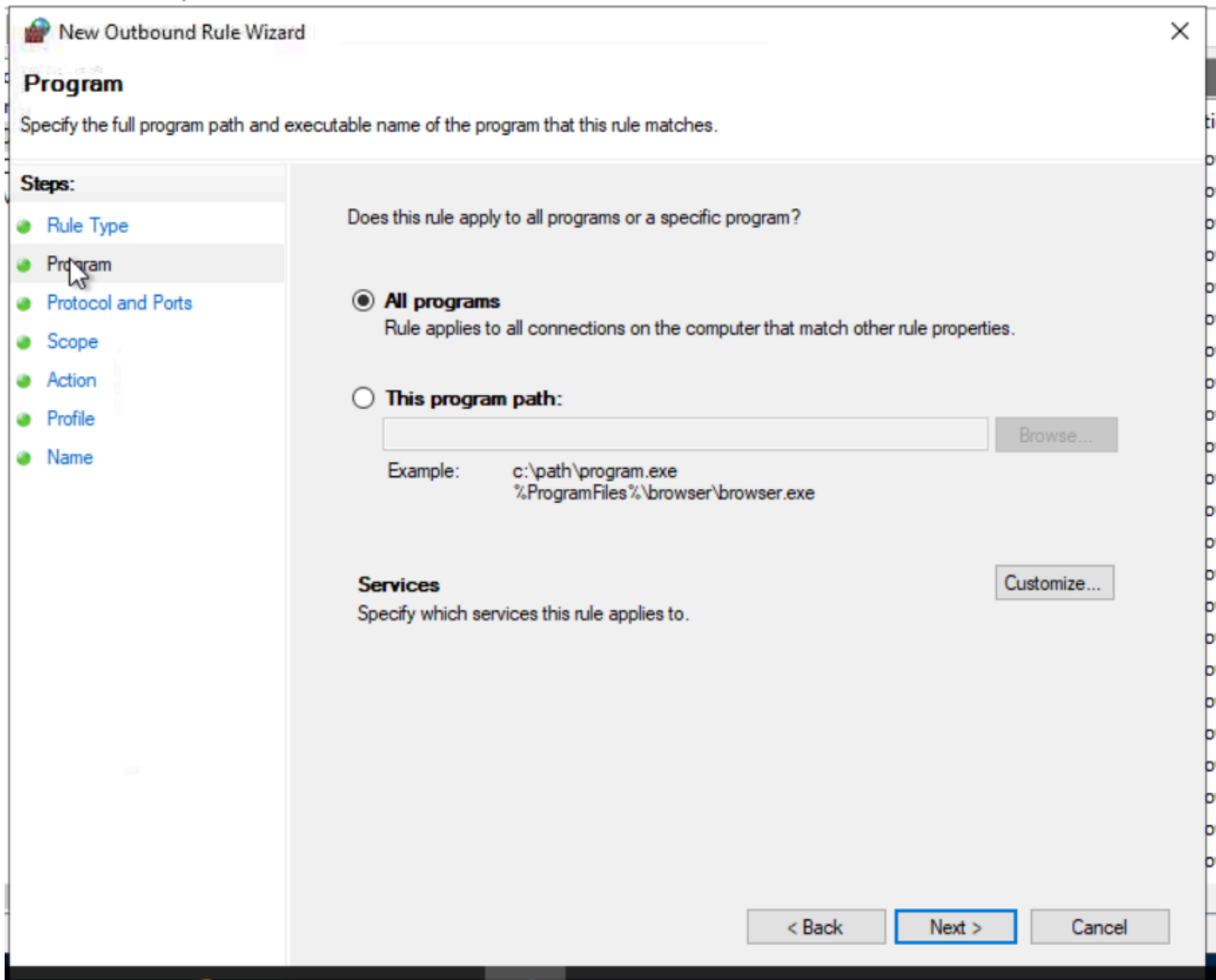
*Yukarıdaki komut veya basit bir tarayıcı isteği, kural öncesinde **10.10.10.10** hedefine yapılan bağlantının başarılı olduğunu ve sunucudan HTTP 200 OK yanıtının döndüğünü gösterecektir.*

Kuralı oluşturmak için **Outbound Rules** (Giden Kuralları) > **New Rule** (Yeni Kural) sihirbazı başlatılır. Adımlar ve teknik gerekçeleri şunlardır:

1. **Rule Type (Kural Tipi) - Custom:** Özel bir port/protokol kısıtlaması yapacağımız için "Custom" (Özel) seçilir. Bu, bize OSI referans modelinin 3. (Ağ) ve 4. (Taşıma) katmanlarında tam kontrol sağlar.



2. **Program - All programs:** Kısıtlama belirli bir tarayıcıyı (örn. chrome.exe) değil, sistemdeki *tüm* süreçlerin (işletim sistemi servisleri dahil) web portlarına erişimini engellemelidir.



3. Protocols and Ports (Protokol ve Portlar):

- **Protocol Type: TCP** (Transmission Control Protocol). Çünkü HTTP ve HTTPS protokolleri güvenilir veri iletimi için bağlantı yönelimli (connection-oriented) olan TCP'yi kullanır.
- **Local Port:** Kendi sistemimizden çıkan bağlantılarda işletim sistemi rastgele geçici (ephemeral) portlar atadığı için burası varsayılan bırakılır.
- **Remote Port: Specific Ports** (Belirli Portlar) seçilerek **80,443** yazılır.
- **Mantık:** "Benim sistemimden (hangi porttan çıkarsa çıksın), karşı taraftaki **80** veya **443** numaralı portlara giden tüm TCP paketlerini yakala."

New Outbound Rule Wizard

Protocol and Ports

Specify the protocols and ports to which this rule applies.

Steps:

- Rule Type
- Program
- Protocol and Ports
- Scope
- Action
- Profile
- Name

To which ports and protocols does this rule apply?

Protocol type: TCP

Protocol number: 6

Local port: All Ports

Example: 80, 443, 5000-5010

Remote port: Specific Ports

80, 443

Example: 80, 443, 5000-5010

Internet Control Message Protocol (ICMP) settings: Customize...

< Back Next > Cancel

4. **Scope (Kapsam):** IP kısıtlaması yapmadığımız için yerel ve uzak IP adresleri kısmı "Any" (Herhangi) olarak bırakılır. Bu, hedefin IP'si ne olursa olsun kuralın tetikleneceği anlamına gelir.

New Outbound Rule Wizard

Scope

Specify the local and remote IP addresses to which this rule applies.

Steps:

- Rule Type
- Program
- Protocol and Ports
- Scope**
- Action
- Profile
- Name

Which local IP addresses does this rule apply to?

☒ Any IP address

☐ These IP addresses:

Add... Edit... Remove

Customize the interface types to which this rule applies: Customize...

Which remote IP addresses does this rule apply to?

☒ Any IP address

☐ These IP addresses:

Add... Edit... Remove

< Back Next > Cancel

5. **Action (Eylem) - Block the connection:** Kural eşleştğinde alınacak aksiyondur. Paketler hedefe yönlendirilmeden işletim sistemi seviyesinde düşürülür (drop).

Action

Specify the action to be taken when a connection matches the conditions specified in the rule.

Steps:

- Rule Type
- Program
- Protocol and Ports
- Scope
- Action
- Profile
- Name

What action should be taken when a connection matches the specified conditions?

☐ **Allow the connection**

This includes connections that are protected with IPsec as well as those are not.

☐ **Allow the connection if it is secure**

This includes only connections that have been authenticated by using IPsec. Connections will be secured using the settings in IPsec properties and rules in the Connection Security Rule node.

Customize...

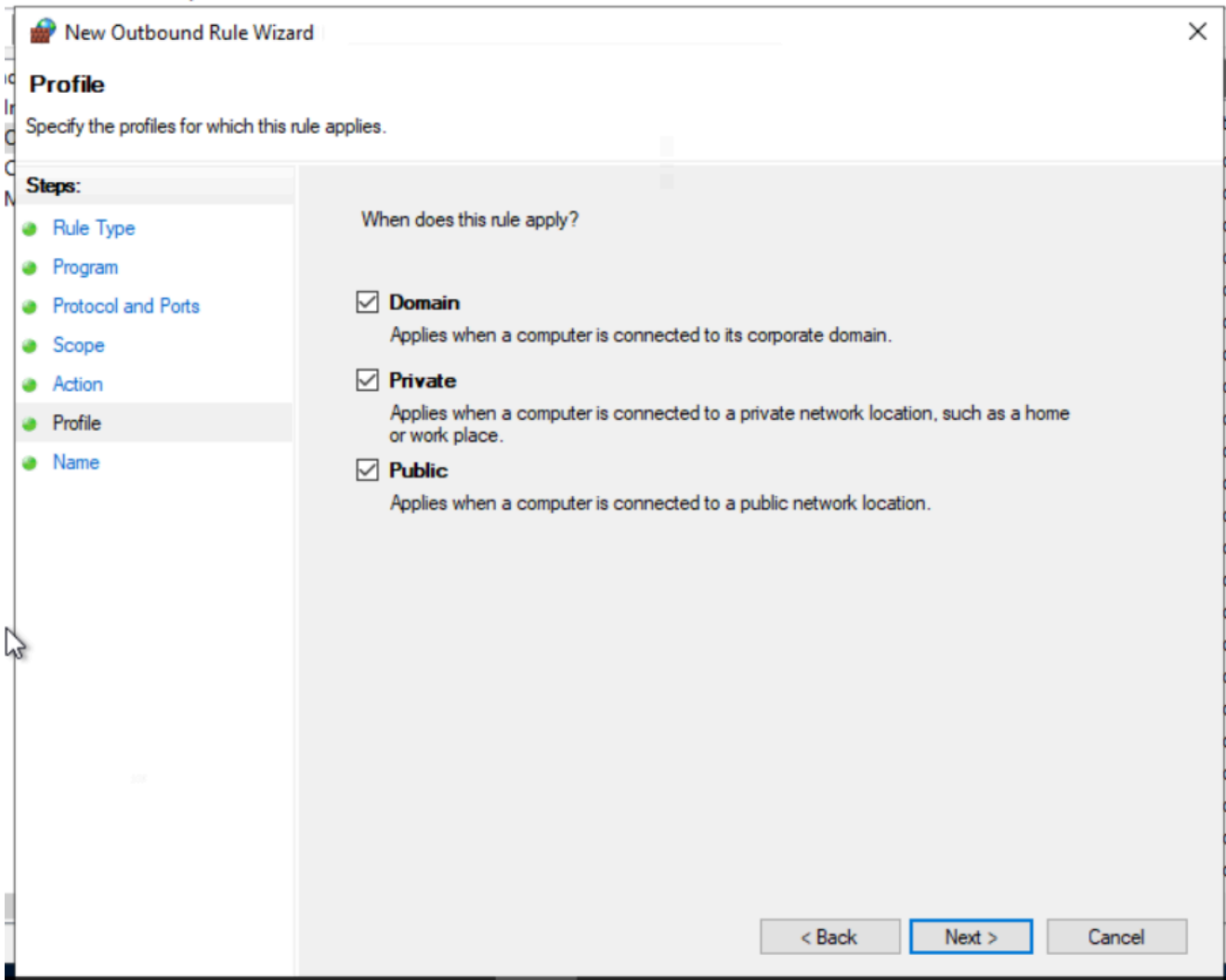
☒ **Block the connection**

< Back

Next >

Cancel

6. **Profile (Profil):** Kuralın atlatılmasını (bypass) engellemek için tüm profiller (Domain, Private, Public) işaretlenir. Aksi takdirde, ağ değiştiğinde sistem internete çıkmaya devam edebilir.



Doğrulama (Validation) ve Arka Plan Analizi

Kural oluşturulup aktif edildikten sonra hedef IP'ye tekrar erişim denenir:

```
Invoke-WebRequest -Uri http://10.10.10.10/ -TimeoutSec 5
# Çıktı:
# Invoke-WebRequest : Unable to connect to the remote server
# (Kavramsal Çıktı: İşletim sistemi bu isteği blokladığı için TCP SYN paketi
ağ kartından çıkmadan engellenir.)
```

DİKKAT: Çıktıda alınan hata, karşı sunucunun (10.10.10.10) kapalı olduğu veya ağda bir kopukluk olduğu anlamına gelmez. Arka planda gerçekleşen olay; tarayıcı veya PowerShell'in hedef port **80**'e bir **TCP SYN** paketi oluşturması, ancak bu paketin dışarı çıkmak üzere ağ yığınına (network stack) iletildiği anda **Windows Defender Firewall** tarafından kural setiyle eşleştirilip (Match) "Block" aksiyonu gereği sessizce düşürülmesidir (Dropped). Sistemin dışarıyla olan web iletişimi böylece tamamen izole edilmiştir.

Linux Güvenlik Duvarı Mimarisi: Netfilter ve UFW Yönetimi

Linux işletim sistemlerinde ağ trafiği kontrolü, Windows'taki gibi tek bir grafik arayüz uygulamasından ziyade, çekirdek (kernel) seviyesinde çalışan modüller ve bu modüllere komut gönderen çeşitli kullanıcı alanı (user-space) araçlarının birleşiminden oluşur. Bir Linux sistemini savunurken veya sızma testlerinde ağ kısıtlamalarını aşmaya (Evasion) çalışırken, bu hiyerarşiyi kavramak teknik uzmanlığın temelidir.

Çekirdek (Kernel) Seviyesi: Netfilter

Linux'ta tüm ağ trafiği filtreleme (Packet Filtering), Ağ Adresi Çevirisi (**NAT** - Network Address Translation) ve bağlantı takibi (Connection Tracking / Stateful Inspection) işlemlerinin kalbi **Netfilter** framework'üdür. Netfilter doğrudan Linux çekirdeğine entegredir. Ancak, Netfilter ile doğrudan etkileşime girmek karmaşık olduğu için çeşitli ön yüz (frontend) araçları geliştirilmiştir:

- **iptables**: Yıllardır endüstri standardı olan, Netfilter'a kurallar (chain, table mantığıyla) yazılmasını sağlayan en yaygın temel araçtır.
- **nftables**: Modern Linux dağıtımlarında **iptables**'ın yerini alan, daha gelişmiş sözdizimine ve çok daha yüksek paket işleme performansına sahip halefidir.
- **firewalld**: Daha çok Red Hat tabanlı sistemlerde kullanılan, ağları güvenilirlik seviyelerine göre "Bölgelere" (Zone-based) ayıran dinamik bir yönetim aracıdır.

UFW (Uncomplicated Firewall) ve Mantıksal Katmanı

ufw, adından da anlaşılacağı üzere, doğrudan karmaşık **iptables** veya **nftables** sözdizimiyle uğraşmak istemeyen sistem yöneticileri için tasarlanmış bir ön yüz (frontend) yöneticisidir.

ÖNEMLİ: **ufw** kendi başına bir güvenlik duvarı değildir. **ufw** üzerinden yazdığınız tüm basit komutlar, arka planda doğrudan **iptables** kurallarına çevrilerek **Netfilter**'a iletilir. Yani UFW kullanırken aslında sistemi iptables ile korursunuz.

Güvenlik Duvarı Durum Analizi ve Aktivasyonu

Bir Linux sunucusuna sızıldığında veya yapılandırma yapıldığında atılacak ilk adım, hedefin mevcut savunma durumunu (posture) anlamaktır.

```
user@ubuntu:~$ sudo ufw status
Status: inactive
```

Yukarıdaki çıktı, UFW servisinin şu anda ağ trafiğine müdahale etmediğini gösterir. Ancak bu durum, sistemde hiçbir güvenlik kuralı olmadığı anlamına gelmez; UFW kapalı olsa bile, doğrudan sistem yöneticisi tarafından yazılmış ham **iptables** kuralları aktif olabilir. (Bu yüzden derinlemesine analizde daima `iptables -L` de kontrol edilmelidir).

UFW'yi sistemde aktif hale getirmek ve her yeniden başlatmada (reboot) otomatik olarak çalışmasını sağlamak için `enable` parametresi kullanılır:

```
user@ubuntu:~$ sudo ufw enable
Firewall is active and enabled on system startup
```

Bu komut çalıştırıldığında arka planda UFW servisi systemd tarafından başlangıç servislerine eklenir ve varsayılan kural setleri çekirdeğe yüklenir. Kapatmak için tahmin edilebileceği üzere `disable` parametresi verilir.

Varsayılan İlkeler (Default Policies)

Güvenlik duvarı mimarisinde, hiçbir spesifik kurala uymayan paketlere ne olacağını belirleyen ana kurala **Default Policy** denir. Güvenlik sıkılaştırma (Hardening) süreçlerinde "Zimni Reddetme" (Implicit Deny) prensibi gereği tüm gelen bağlantılar bloklanır, ancak sunucunun yamaları indirebilmesi veya dış servislere ulaşabilmesi için giden bağlantılara izin verilir.

```
user@ubuntu:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
```

Bu komut ile sunucunun dış dünyaya başlatacağı tüm bağlantı istekleri (Örneğin, bir C2 sunucusuna yapılacak Reverse Shell bağlantısı veya bir paket yöneticisi güncellemesi) serbest bırakılmıştır. Eğer burayı `deny outgoing` yapsaydık ve DNS (Port **53**) veya HTTP/S (Port **80**, **443**) için özel izinler tanımlamasaydık, sunucu internete hiçbir şekilde çıkamazdı.

Spesifik Trafik Kısıtlaması: Gelen Bağlantıları Reddetme (Deny Inbound)

Ağ üzerinde sadece belirli servislere müdahale etmek için port ve protokol belirtmemiz gerekir. Kritik bir servis olan SSH (Secure Shell) trafiğini dışarıdan gelen bağlantılara kapatmak için aşağıdaki komut kullanılır.

DİKKAT: Uzaktaki bir sunucuda (örneğin AWS veya Azure üzerindeki bir VM'de) bu komutu çalıştırırsanız ve o anki oturumunuz koparsa, sisteme bir daha SSH üzerinden erişemezsiniz (Kendinizi dışarı kitleme / Lockout durumu).

```
user@ubuntu:~$ sudo ufw deny 22/tcp
Rule added
Rule added (v6)
```

Çıktıdaki mantıksal derinliği incelediğimizde: Komutta sadece **22/tcp** dedik, ancak UFW bize iki adet kural eklediğini söylüyor (`Rule added` ve `Rule added (v6)`). Bunun teknik sebebi, UFW'nin modern ağ standartlarına uygun olarak aynı anda hem **IPv4** hem de **IPv6** için kural oluşturmasıdır. Eğer sadece IPv4'ü engelleseydik, saldırganlar IPv6 üzerinden 22. porta ulaşarak güvenlik duvarımızı atlatabilirdi (Bypass). Ayrıca sadece `22` yazmak yerine `22/tcp` yazarak UFW'ye Taşıma Katmanı'nda (Transport Layer) sadece TCP paketlerini filtrelemesini söyledik; çünkü SSH protokolü UDP üzerinden çalışmaz.

Kural Yönetimi ve Sıralamanın Önemi (Rule Precedence)

Güvenlik duvarları kuralları her zaman **yukarıdan aşağıya (Top-to-Bottom)** doğru sırayla okur. Bir paket bir kuralla eşleştiği (match) an aksiyon alınır ve altındaki kurallar okunmaz. Bu yüzden kuralların sırasını görmek hayati önem taşır.

```
user@ubuntu:~$ sudo ufw status numbered
```

To	Action	From
--	-----	----
[1] 22/tcp	DENY IN	Anywhere
[2] 22/tcp (v6)	DENY IN	Anywhere (v6)

Bu komut bize kuralların indeks numaralarını (1, 2 vb.) verir. DENY IN ibaresi, hedefin (To) bizim makinemizdeki **22/tcp** portu olduğunu ve Anywhere (0.0.0.0/0 - İnternetteki herkes) kaynaklı gelen paketlerin anında düşürüleceğini (Drop) belirtir.

Bir kuralı silmek (Rule Deletion) için kuralın indeks numarasını kullanmak en güvenli yöntemdir. IPv6 için yazılmış olan kuralı (İndeks 2) silelim:

```
user@ubuntu:~$ sudo ufw delete 2
Deleting:
deny 22/tcp
Proceed with operation (y|n)? y
Rule deleted (v6)
```

Bu adım başarıyla tamamlandığında, (v6) etiketiyle belirtilen IPv6 üzerinden gelen SSH bağlantısı reddetme kuralı **Netfilter** üzerinden kaldırılmış olur. Artık IPv6 üzerinden 22. porta gelen bir paket, bu reddetme kuralıyla karşılaşmayacağı için "Default Policy" (Varsayılan İlke) ne diyorsa ona tabi olacaktır.